VIBE CODING

YAZILIM GELİŞTİRME STANDARTLARI

BLUEPRINT

AI destekli yazılım geliştirmede kontrol modeli, denetim çerçevesi ve yaygınlaştırma yaklaşımı

1 **Referans Model ve Kontroller**
AI destekli geliştirme referans modeli, rol sınırları, ölçülmüş risk asimetrisi, olgunluk seviyeleri, kontrol kapıları, senaryolar, anti-pattern listesi ve bağlam disiplini. s. 2 – 11

2 **Denetim Çerçevesi ve Yaygınlaştırma**
Kategori ağırlıkları, skorlama ve geçme kararı, tarama soruları, karar kütüğü, kavram sözlüğü, araç eşleme şablonu, yol haritası ve denetimin sınırları. s. 12 – 21

3 **Firma Önerisi**
Belirli bir kurum için mevcut durum özeti, hedef kontrol seti ve devreye alma planı. Değerlendirme bulgularıyla doldurulur. s. 22 – 25

AI-Destekli Yazılım Geliştirme — Referans Model

Komtaş Yazılım Standardı

Niyetten işletime, AI'ın değiştirdiği kontrol noktaları

Araç ve model bağımsız referans model. Hangi kontrolün hangi aşamada ve kim tarafından yapılacağını tanımlar; hangi AI aracının kullanıldığını tanımlamaz.

1. Niyet ve Bağlam

- İş ihtiyacı ve kabul ölçütü
- Bağlam paketi
  kod, şema, kısıt
- AI rules dosyaları
  sürümlenir, review edilir
- Olgunluk seviyesi
  prototip · pilot · üretim
- Veri hassasiyeti sınıfı

2. Üretim

- AI asistanı ile kod üretimi
- Prompt ve bağlam disiplini
- Bağımlılık seçimi
  registry doğrulaması
- Riskli yüzeyin okunması
  authz, veri, dış çağrı
- Sır ve kimlik bilgisi
  asla kod içinde

3. Doğrulama

- Birim ve entegrasyon testi
- Lint ve tip kontrolü
- Yerel güvenlik taraması
- Kendi kendine review
  AI çıktısı varsayılan doğru değil
- Kabul ölçütüne karşı kontrol

4. İnceleme

- İnsan review — zorunlu
- Diff boyutu sınırı
  okunamayan diff review edilmemiştir
- Atfedilebilirlik
  kim, ne zaman, neyi
- AI payının beyanı
- Dört göz — ekip varsa

5. Kapı ve Denetim

- Secrets taraması
- SAST — kural seti
- SCA ve CVE taraması
- SBOM üretimi
- LLM triage
  authorization, iş mantığı, mimari
- Skor ve kategori notu
- Bloklayan bulgu kapısı

6. Dağıtım

- CI/CD hattı
- Environment ayrımı
- Sürümleme ve release notu
- Geri alma (rollback) planı

7. İşletim

- İzleme ve uyarı
- Kanıt arşivi
  90 gün
- MTTR ve trend
- Regresyon denetimi

Kesişen Yetenekler — her aşamada geçerlidir

Kural Seti Sahipliği ve Yönetişim

- Tek kaynak: SAT / Solution Architecture
- Eşik ve dedektör kabul kuralı
- Plugin sürümüyle yayılım

Güvenlik ve Sır Yönetimi

- Secret store ve rotasyon
- Güvenli varsayılan konfigürasyon
- Erişim ve yetkilendirme kalıpları

İzlenebilirlik ve Atfedilebilirlik

- Git künyesi ve commit disiplini
- Denetim izi: araç, kural, dosya, satır
- Değişikliğin gerekçesi

Test Bütünlüğü

- Test varlığı ve oranı
- Silinen test tespiti
- Kabul ölçütü karşılığı

Uyum ve Kanıt Üretimi

- Çerçeve görünümü: ISO, SOC 2, ASVS, SSDF
- Üç durumlu skala: kanıt sağlandı / kısmi / üretilemedi
- Kanıt paketi zaman serisi

Ölçüm ve Eşikler

- Kategori ağırlıkları toplamı 100
- Materyal yeterliliği eşiği
- Yanlış pozitif oranı ölçümü

NOTLAR

- Model araç bağımsızdır; hangi AI asistanının kullanıldığını belirlemez.
- Aşamalar sıralıdır ancak her aşama her projede aynı derinlikte uygulanmaz.
- Olgunluk seviyesi hangi kontrollerin zorunlu olduğunu belirler.

RENK LEJANDI — KONTROL TİPİ

- İnsan Kararı
- Araç Yeteneği
- Süreç Kapısı
- Yönetişim

BU MODEL NASIL KULLANILIR

Kontrol noktalarının referans kataloğudur. Proje standardında yalnızca olgunluk seviyesinin gerektirdiği kontroller zorunlu tutulur.

Rol Sınırları — Kim Neyi Yapar, Neyi Yapmaz

AI asistanı ekibe bir üye eklemez; mevcut rollerin sınırlarını değiştirir. Değişen sınırlar yazılı olmazsa sorumluluk boşlukta kalır.

ROL	TİP	YAPAR	YAPMAZ
Geliştirici	İnsan	Niyeti ve kabul ölçütünü tanımlar · değişikliği review edilebilir boyutta tutar · riskli yüzeyi okur · kararın sahibidir	Okunamayacak boyuttaki değişikliği onaylamaz · AI çıktısını doğrulanmış kabul etmez
AI Kodlama Asistanı	Araç	Kod, test ve dokümantasyon taslağı üretir · alternatif yaklaşım önerir · tekrar eden işi hızlandırır	Karar vermez · sorumluluk taşımaz · ürettiği kodun doğruluğunu garanti etmez
İnsan Review	Süreç	Değişikliğin gerekçesini ve kapsamını denetler · iş mantığı ve yetkilendirme kusurlarını arar	Stil tartışmasına indirgenmez · otomatik araçların yaptığı işi tekrarlamaz
Deterministik Denetim Araçları	Araç	Secret, SAST, SCA, SBOM ve konfigürasyon bulgularını üretir · tekrarlanabilir ve kanıtlanabilir	Yorum yapmaz · authorization ve iş mantığı kusurlarını göremez · yanlış pozitif üretir
LLM Triage	İnsan + Araç	Yanlış pozitifleri eler · araçların göremediği authorization, iş mantığı ve mimari kusurları arar	Bloklayan bulguyu tek başına kapatamaz · eleme yetkisi kategori bazında sınırlıdır
CI Kapısı	Süreç	Eşikleri uygular · bloklayan bulgu varsa birleştirmeyi durdurur · denetim izini üretir	Eşiği müzakere etmez · bypass edilebilir hale getirilmez
Kural Seti Sahibi (SAT)	Yönetişim	Kural setinin, eşiklerin ve dedektör kabul kurallarının tek kaynağıdır	Proje bazında istisna tanımlamaz · yerel kopya düzenlenmesine izin vermez
Ürün / Proje Sahibi	İnsan	Olgunluk seviyesini ve veri hassasiyetini belirler · riski kabul eder veya reddeder	Teknik eşiği düşürerek riski ortadan kaldıramaz
İç Denetim	Yönetişim	Kanıt paketini, trendi ve açık bloklayan bulguları izler	Tek bir rapora bakarak uyum kararı vermez

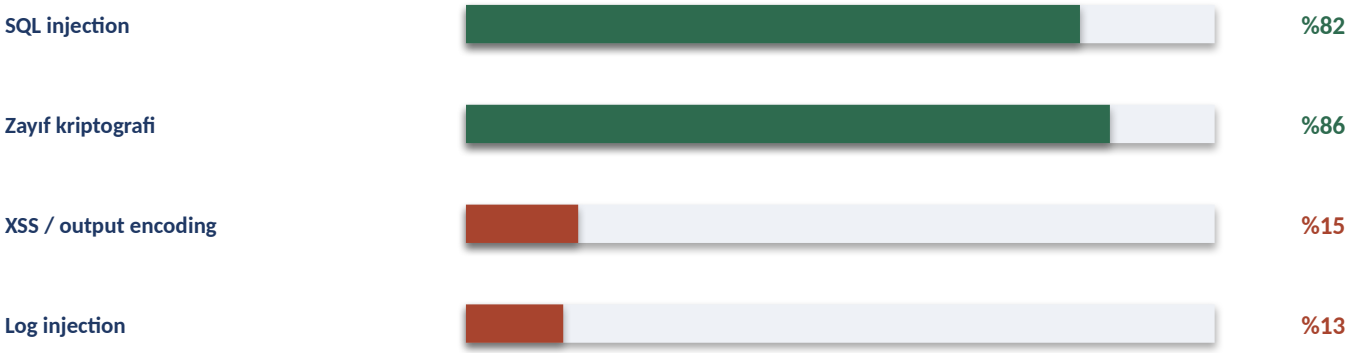
Kararın sahibi her zaman insandır. İnsandan beklenen her satırı okumak değil; değişikliği okunabilir boyutta tutmak ve riskli yüzeyi okumaktır. Review edilemeyecek kadar büyük bir değişiklik, review edilmemiş değişikliktir.

AI Kodunun Ölçülmüş Asimetrisi

AI üretimi kod her güvenlik kategorisinde aynı performansı göstermez. Kontrol ağırlığı, modelin zayıf olduğu kategorilerde olmalıdır.

GÜVENLİK TESTİNDEN GEÇME ORANI · AI üretimi kod

Veracode ölçümü, Mart 2026 — kategori bazında geçme oranı



Modeller yaygın ve iyi belgelenmiş zafiyetleri öğrenmiş durumda. Az örneklenen, bağlama bağlı ve "sessiz" kategorilerde ise zayıf.

BUNUN ANLAMI

- Genel bir "AI kodu güvenli mi" sorusunun cevabı yoktur; soru kategori bazında sorulur.
- Kontrol ağırlığı, modelin zayıf olduğu kategorilere kaydırılır: output encoding, log sanitization, CORS, SSRF, CSRF.
- Geliştiricinin deneyimi bu asimetriyi kapatmaz; zayıf kategoriler gözle fark edilmesi en zor olanlardır.
- SAST katmanı çalışmadıysa "bu kategorilerde bulgu yok" ifadesi geçersizdir — hiç taranmamıştır.

AI'A ÖZGÜ KÖR NOKTALAR — klasik çerçevelerde karşılığı yoktur

Hallucinated package — M01

AI var olmayan bir paket önerir; saldırgan o adı registry'ye kaydeder.

Slopsquatting — M02

Yeni açılmış, benzer adlı zararlı paket. Minimum paket yaşı kontrolü gerekir.

Rules file persistence — M18

AI rules dosyaları sürümlenmez ve review edilmezse sessiz davranış değişikliği üretir.

Gizli / bidi Unicode — M19

Gözle görünmeyen karakterler kodun okunan hali ile çalışan halini ayırır.

İş mantığı ve authorization — M23

Deterministik araçların göremediği kusurlar; ayrı bir inceleme katmanı gerekir.

Commit disiplini kaybı — M17

Büyük ve açıklamasız commit'ler atfedilebilirliği ve review'ı imkânsız kılar.

Üç Olgunluk Seviyesi — Kontrol Seviyeyle Ölçeklenir

Her kod aynı kontrolden geçmez. Seviye, kodun kime ve hangi veriyle dokunduğuna göre belirlenir; geliştirme yöntemine göre değil.

1. PROTOTİP

Fikrin çalışıp çalışmadığını görmek için üretilir. Kullanıcısı yoktur, verisi sentetiktir.

ZORUNLU KONTROLLER

- Secret taraması (pre-commit)
- Gizli / bidi Unicode kontrolü
- Paket adı doğrulaması

BU SEVİYEDE GEVŞETİLEBİLİR

- SAST eşiği
- Test coverage
- SBOM üretimi
- İnsan review zorunluluğu

ÇIKIŞ KOŞULU — Gerçek kullanıcı veya gerçek veri ile temas edecekse prototip seviyesinde kalamaz.

2. PİLOT

Sınırlı ve bilinen bir kullanıcı grubuna açılır. Gerçek veri girebilir, geri dönüş mümkündür.

ZORUNLU KONTROLLER

- Prototip kontrollerinin tamamı
- SAST ve SCA taraması (advisory)
- SBOM üretimi ve saklanması
- İnsan review — en az bir onay
- Denetim izi: kim neyi ne zaman dağıttı

BU SEVİYEDE GEVŞETİLEBİLİR

- Skor eşiği (blocking değil)
- Coverage eşiği
- Çerçeve eşlemesi raporlaması

ÇIKIŞ KOŞULU — Skor 4–6 hafta boyunca istikrarlı biçimde 85 üzerinde kalmadan üretime geçiş önerilmez.

3. ÜRETİM

Genel kullanıma veya düzenlemeye tabi bir müşteriye açılır. Geri dönüş maliyetlidir.

ZORUNLU KONTROLLER

- Pilot kontrollerinin tamamı
- CI kapısı blocking modda
- Bloklayan bulgu = birleştirme yok
- LLM triage katmanı
- Kanıt paketi — tarihli arşiv
- Kural seti merkezden, yerel kopya yok

BU SEVİYEDE GEVŞETİLEBİLİR

- Yok — bu seviyede kontrol gevşetilmez; kapsam daraltılır

ÇIKIŞ KOŞULU — Kontrol gevşetilmesi gereken durum, seviyenin düşürülmesiyle değil kapsamın küçültülmesiyle çözülür.

Veri hassasiyeti seviyeyi yukarı çeker, aşağı çekmez. Kişisel veri işleyen bir pilot, üretim kontrollerine tabi tutulur; düzenlemeye tabi müşteriye açılan hiçbir bileşen pilot seviyesinde bırakılmaz.

Kontrol Kapıları — Nerede Durulur, Kim Karar Verir

Kapılar sırayla uygulanır ve her biri farklı bir kusur sınıfını yakalar. Bir kapının atlanması, sonraki kapıların o sınıfı yakalayacağı anlamına gelmez.

	KAPI	NE DOĞRULANIR	KARAR	GEÇEMEZSE
K1	**Niyet ve kabul ölçütü**	Ne yapılacağı ve neyin "bitti" sayılacağı yazılı mı; kapsam sınırı belirli mi	Geliştirici	Üretime başlanmaz — tanımsız niyet, doğrulanamaz çıktı üretir
K2	**Pre-commit**	Secret, gizli / bidi Unicode, büyük ikili dosya	Otomatik	Commit oluşmaz — sır bir kez geçmişe girdiğinde silinmesi değil rotasyonu gerekir
K3	**Bağımlılık doğrulaması**	Paket gerçekten var mı, kaç günlük, lisansı ne, bilinen zafiyeti var mı	Otomatik	Paket eklenmez — hallucinated package ve slopsquatting bu kapıda durdurulur
K4	**Statik analiz**	SAST, konfigürasyon, output encoding, log sanitization, CORS, SSRF	Otomatik	Bulgu PR'a yazılır; advisory modda uyarı, blocking modda engel
K5	**İnsan review**	Değişiklik boyutu review edilebilir mi; yetkilendirme ve iş mantığı etkisi ne	İnsan	Birleştirme yapılmaz — okunamayan diff önce bölünür; araçların göremediği tek katman burasıdır
K6	**LLM triage**	Yanlış pozitif elemesi ve araçların göremediği kusurların aranması	İnsan + Araç	Eleme gerekçesiz kabul edilmez; bloklayan bulguyu tek başına kapatamaz
K7	**Skor ve eşik**	Kategori ağırlıklı skor; bloklayan bulgu var mı	Otomatik	Bloklayan bulgu varsa skor ne olursa olsun geçilmez
K8	**Kanıt arşivi**	Bulgu seti tarihli olarak saklandı mı; trend ve açık bulgular izlenebilir mi	Yönetişim	Tek rapor uyum kanıtı değildir; zaman serisi olmadan iyileşme gösterilemez

İnsan kararı

Otomatik / süreç kapısı

Yönetişim

K2–K4 ve K7 otomatiktir; K1 ve K5 devredilemez. K6 ve K8 kural setinin sahibine bağlıdır.

Senaryo — Bir Özellik AI Asistanıyla Uçtan Uca Geliştiriliyor

Asistanın girdiği yer adım 4–6'dır. Öncesindeki ve sonrasındaki adımlar, asistan kullanılsın ya da kullanılmasın aynıdır.

ADIM	AŞAMA	YAPILAN İŞ	ÇIKTI
NİYET VE BAĞLAM · üretim öncesi			
1	Niyet	İhtiyaç, kabul ölçütü ve kapsam dışı bırakılanlar yazılır	Tanımlı iş maddesi
2	Niyet	Olgunluk seviyesi ve veri hassasiyeti belirlenir	Uygulanacak kontrol seti
3	Bağlam	Asistana verilecek bağlam seçilir: ilgili modüller, sözleşmeler, kural dosyası	Sınırlı ve amaçlı bağlam
ÜRETİM · kod ve test			
4	Üretim	Asistan kod taslağı üretir; geliştirici alternatifleri karşılaştırır	Kod taslağı
5	Üretim	Geliştirici değişikliği review edilebilir parçalara böler ve riskli yüzeyi okur	Sahiplenilmiş değişiklik
6	Üretim	Test, asistandan bağımsız bir adımda ve kabul ölçütünden türetilerek yazılır	Bağımsız test seti
DOĞRULAMA · otomatik katman			
7	Doğrulama	Pre-commit: secret, gizli / bidi Unicode, büyük ikili dosya	Temiz commit
8	Doğrulama	Bağımlılıklar doğrulanır: paket var mı, yaşı, lisansı, bilinen zafiyeti	Doğrulanmış bağımlılık listesi
9	Doğrulama	SAST, konfigürasyon ve AI kör noktası kuralları çalışır	Bulgu seti
10	Doğrulama	SBOM üretilir ve commit ile birlikte saklanır	Sürümlenmiş SBOM
İNCELEME · insan ve LLM			
11	İnceleme	İnsan review: gerekçe, kapsam, yetkilendirme ve iş mantığı etkisi	Review onayı
12	İnceleme	LLM triage: yanlış pozitif elemesi ve araçların göremediği kusurların aranması	Gerekçeli triage sonucu
KAPI · karar			
13	Kapı	Skor ve bloklayan bulgu kontrolü; advisory veya blocking modda karar	Kapı kararı
DAĞITIM			
14	Dağıtım	Kim, neyi, hangi commit ile dağıttı — denetim izine yazılır	Dağıtım kaydı
İŞLETİM			
15	İşletim	Çalışma zamanı izleme; bulgu seti tarihli olarak arşive eklenir	Kanıt paketi girdisi

Adım 6 ayrı yazılmıştır çünkü testin kodla aynı üretimden gelmesi, kodun kendi iddiasını kendi doğrulaması anlamına gelir. Test kabul ölçütünden türetilir; üretilen koddan değil.

Senaryo — Önerilen Bir Bağımlılık Doğrulanıyor

AI asistanları var olmayan paket adları üretebilir. Saldırganın yöntemi, sık üretilen bu adları registry'ye önceden kaydetmektir.

ADIM	TÜR	KONTROL	SONUÇ
ÖNERİ · asistan çıktısı			
1	Öneri	Asistan bir işlev için paket önerir ve import satırını yazar	Aday bağımlılık
DOĞRULAMA SORULARI · sırayla, ilk eleyen durdurur			
2	Soru	Paket registry'de gerçekten var mı	Yoksa: hallucinated package — reddedilir
3	Soru	Paket kaç gün önce yayımlandı	Minimum yaşın altındaysa beklemeye alınır
4	Soru	Ad, yaygın bir pakete tek karakter mesafede mi	Benzer ad: slopsquatting şüphesi — manuel onay
5	Soru	İndirme sayısı, sürüm geçmişi ve bakım izi tutarlı mı	Tek sürüm, sıfır geçmiş: reddedilir
6	Soru	Lisans kurumun deny-list'inde mi	Deny-list: reddedilir
7	Soru	Bilinen zafiyet kaydı var mı	Kritik zafiyet: sürüm sabitlenir veya reddedilir
KALİBRASYON			
8	Hariç	Monorepo yerel paketleri registry sorgusundan çıkarılır	Hariç tutulanlar rapora yazılır
KAYIT			
9	Kayıt	Kabul edilen bağımlılık SBOM'a işlenir	Sürümlenmiş SBOM
10	Kayıt	Red veya kabul kararı gerekçesiyle karar kütüğüne yazılır	Karar kaydı

Adım 8 kalibrasyon maddesidir ve ölçülmüş bir hatadan gelir: monorepo yerel paketleri registry'ye sorulduğunda tek bir koşuda 52 yanlış bloklayan bulgu üretilmişti. Hariç tutulanlar rapordan silinmez, bilgi satırı olarak yazılır.

Senaryo — Bulgudan Kapanışa

Sıra korunur: araç üretir, LLM yorumlar, karar deterministik eşiklerle verilir. Sıranın bozulması, yorumun ölçümün yerine geçmesi demektir.

ADIM	AŞAMA	YAPILAN İŞ	ÇIKTI
ÜRETİM · deterministik katman			
1	**Bulgu**	Deterministik araç katmanı bulguyu üretir; kaynak dosya, satır ve kural kimliği kayıtlıdır	Ham bulgu
2	**Bağlam**	Bulgunun çevresindeki kod ve çağrı bağlamı triage girdisine eklenir	Bağlamlı bulgu
ELEME · yanlış pozitif			
3	**Eleme**	Yanlış pozitif mi — gerekçe yazılır; gerekçesiz eleme kabul edilmez	Elenmiş veya doğrulanmış
4	**Sınır**	Eleme yetkisinin kapalı olduğu kategorilerde bulgu elenemez	Zorunlu inceleme
GENİŞLETME · araçların göremediği			
5	**Arama**	Araçların göremediği alanlar ayrıca aranır: authorization, iş mantığı, mimari	LLM kaynaklı bulgu
6	**Yetki**	LLM kaynaklı bulgu skora eklenir; kapıyı tek başına kapatamaz	Asimetrik yetki uygulanır
SINIFLAMA VE KARAR			
7	**Sınıflama**	Bağlam bulguyu susturmaz, yeniden sınıflandırır — gerekçe raporda kalır	Uygulanabilir / uygulanamaz
8	**Karar**	Skor yeniden hesaplanır; bloklayan bulgu varsa skor dikkate alınmaz	Kapı kararı
KAPANIŞ VE KANIT			
9	**Kapanış**	Düzeltme yapılır veya risk gerekçesiyle kabul edilir; ikisi de yazılır	Kapanış kaydı
10	**Arşiv**	Bulgu seti tarih ve commit ile arşive eklenir; yaşam süresi izlenir	Kanıt paketi

Eleme oranı raporda açıkça yazılır. Triage'ın kaç bulguyu elediği gizlenirse, raporun güvenilirliği ölçülemez hale gelir; yüksek eleme oranı ya kural setinin ya da elemenin kalibre edilmesi gerektiğini gösterir.

Yapılmaması Gerekenler

AI destekli geliştirmede sık karşılaşılan hatalar; neden cazip göründükleri, neyi bozdukları ve yerine ne konduğu.

YAPILMAMASI GEREKEN	NEDEN CAZİP GÖRÜNÜR	NE BOZULUR	BUNUN YERİNE
Büyük bir AI diff'ini okumadan onaylamak	Asistan kodu derli toplu ve kendinden emin görünür; değişiklik büyüdükçe okumak imkânsızlaşır ve onay formaliteye döner	Yetkilendirme ve iş mantığı kusurları hiçbir araç tarafından yakalanmaz; tek katman kapanmış olur	**Değişiklik review edilebilir boyuta bölünür; riskli yüzey okunur, geri kalanı davranışla doğrulanır**
Testi de aynı asistana yazdırmak	Test yazımı maliyetli; aynı oturumda üretilince bedava görünür	Kod kendi iddiasını kendi doğrular; beyan ile gerçek arasındaki fark görünmez kalır	**Test kabul ölçütünden türetilir ve ayrı bir adımda yazılır**
Asistana tüm repoyu bağlam olarak vermek	Daha çok bağlam daha iyi cevap verir sanılır	Sır ve kişisel veri gereksiz yere dışarı çıkar; cevap kalitesi bağlam gürültüsüyle düşer	**Bağlam amaçlı seçilir: ilgili modüller, arayüz sözleşmeleri ve kural dosyası**
Kural dosyalarını sürümlememek	Yerel bir ayar dosyası gibi görünür, review'a değmez sanılır	Asistanın davranışı sessizce değişir; aynı repoda farklı geliştiriciler farklı standart üretir	**AI rules dosyaları koda dahildir: sürümlenir, review edilir, merkezden dağıtılır**
Büyük ve açıklamasız commit atmak	Asistan çok sayıda dosyayı birlikte değiştirir; bölmek zahmetli gelir	Review fiilen imkânsızlaşır, atfedilebilirlik kaybolur; hangi değişikliğin neden yapıldığı sonradan kurulamaz	**Commit tek bir niyeti taşır ve gerekçesini yazar**
İlk kurulumda kapıyı blocking açmak	Kontrol ciddiye alınsın isteniyor; sertlik güven veriyor gibi görünür	Ekip denetimi bypass etmenin yolunu bulur; kontrol kâğıt üstünde kalır	**4–6 hafta advisory çalıştırılır; skor istikrarlı biçimde 85 üzerine çıkınca blocking'e geçilir**
Skoru geçme kararı yerine koymak	Tek sayı yönetime anlatmak kolaydır	Bloklayan bir bulgu yüksek skorun arkasında gizlenir	**Bloklayan bulgu varsa skor ne olursa olsun geçilmez; skor yalnızca iyileşmeyi izler**
Küçük kod tabanının yüksek skorunu başarı saymak	Hiçbir kurala takılmayan repo temiz görünür	Ölçülecek materyal yokken üretilen skor, gerçek bir repoyu ölçen skordan yüksek çıkar	**Eşiğin altındaki kod tabanı skorlanmaz; sonuç "değerlendirilemedi" olarak yazılır**

Bu listedeki her madde kısa vadede hızlandırır. Bedeli ilk denetimde, ilk güvenlik olayında veya kodun ilk kez başka birine devredildiği anda ortaya çıkar.

Prompt ve Bağlam Disiplini

Asistana ne verildiği, çıktının kalitesini ve kurumun veri sınırını birlikte belirler. Bağlam seçimi teknik değil, politika kararıdır.

VERİLİR

- Değişikliğin yapılacağı modül ve doğrudan bağımlılıkları
- Arayüz sözleşmeleri, tip tanımları, şema dosyaları
- Kabul ölçütü ve kapsam dışı bırakılanlar
- Projenin kural dosyası — sürümlenmiş ve review edilmiş hali
- Benzer bir işin daha önce nasıl çözüldüğüne dair bir örnek
- Varsa ilgili hata kaydı veya test çıktısı

VERİLMEZ

- Üretim sırları, anahtarlar, token ve bağlantı dizgileri
- Gerçek kişisel veri içeren örnek kayıtlar
- Müşteri sözleşmesi veya ticari sır niteliğindeki belgeler
- İlgisiz modüller — bağlam gürültüsü cevap kalitesini düşürür
- Tüm repo; “ne olur ne olmaz” gerekçesiyle geniş bağlam
- Başka müşteriye ait kod veya yapılandırma

YAZIYA DÖKÜLÜR

- Hangi asistan ve hangi sürüm kullanıldı
- Hangi bağlam verildi — dosya listesi düzeyinde
- Kural dosyasının o commit’teki hali
- Üretilen kodun hangi kısmı kabul edildi, hangisi yeniden yazıldı
- Reddedilen alternatif ve reddedilme gerekçesi
- Kararın sahibi olan geliştirici

SIK SORULANLAR

Kural dosyası nedir

Asistanın davranışını yönlendiren, repo içinde duran yapılandırma. Koda dahildir: sürümlenir, review edilir.

Neden merkezden dağıtılır

Yerel kopyalar düzenlenirse aynı repoda farklı standartlar oluşur; denetimin anlamı ortak kural setinden gelir.

Neden yazıya dökülür

Altı ay sonra bir bulgu geldiğinde, kodun hangi bağlamla üretildiği yeniden kurulamıyorsa kök neden analizi yapılamaz.

Sınır nerede çizilir

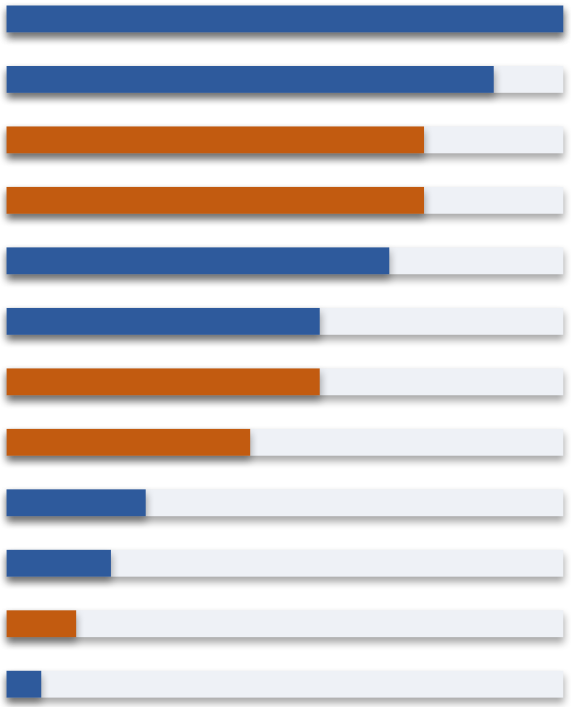
Asistana verilen her şey kurum dışına çıkmış sayılır; sözleşme ve veri sınıflandırması bu varsayımla uygulanır.

Asistana verilen bağlam, kurumun veri sınıflandırma politikasına tabidir. Bu politika yazılı değilse, bağlam disiplini de uygulanamaz.

Denetim Çerçevesi — 23 Madde, 12 Kategori, Ağırlıklı Skor

Ağırlıklar toplamı 100'dür ve kod tabanına göre değişmez. Ağırlık dağılımı, AI üretimi kodun ölçülmüş zayıf kategorilerine göre belirlenmiştir.

KATEGORİ AĞIRLIKLARI



Sır, anahtar ve token sızıntısı	16	Kod, yapılandırma ve geçmişte sabitlenmiş kimlik bilgisi
Statik kod analizi	14	Injection, output encoding, erişim ve girdi doğrulama kusurları
Tedarik zinciri	12	Paket varlığı, yaşı, lisansı, bilinen zafiyet, SBOM bütünlüğü
LLM keşfi	12	Araçların göremediği authorization, iş mantığı ve mimari kusurlar
CI güvenliği	11	Yetki, sır yönetimi, pipeline bütünlüğü ve kapı yapılandırması
Konfigürasyon	9	Sertifika doğrulama, varsayılanlar, açık uçlar ve zayıf ayarlar
İzlenebilirlik	9	Commit disiplini, atfedilebilirlik, denetim izi ve değişiklik gerekçesi
Test bütünlüğü	7	Testin bağımsızlığı, kapsamı ve iddia ile gerçeğin örtüşmesi
Dile özgü analiz	4	Python kaynaklı yaygın kusur kalıpları
Kaynak tüketimi	3	Sınırsız döngü, kontrolsüz bellek ve maliyet kaçağı
AI üretim izleri	2	Gizli / bidi Unicode, kural dosyası kalıcılığı, üretim artığı
Çıktı hijyeni	1	Üretilen artefaktların ve rapor çıktılarının temizliği

AI üretimi koda özgü risk taşıyan kategoriler — toplam ağırlık 42

Klasik güvenlik kategorileri — toplam ağırlık 58

Ağırlık neden burada

Ölçüm, AI üretimi kodun injection ve kriptografide güçlü, output encoding ve log sanitization gibi sessiz kategorilerde zayıf olduğunu gösteriyor. Ağırlık merkezi bu zayıf tarafa kaydırılmıştır.

Ağırlık kim değiştirir

Ağırlıklar ve eşikler merkezden yönetilir; proje bazında istisna tanımlanmaz. Bir eşiğin yanlış olduğu düşünülüyorsa yerel kopya düzenlenmez, gerekçesiyle kural seti sahibine başvurulur.

Yeni dedektör nasıl girer

Dört şart: zafiyetli ve doğru uygulama örneği, beyan edilmiş yanlış pozitif oranı, bilgi → uyarı → blok devreye alma sırası, ve yeni kategori açılıyorsa ağırlığın hangi kategoriden alındığının gerekçesi.

Skorlama ve Geçme Kararı — İkisi Aynı Şey Değildir

Skor iyileşmeyi izlemek içindir. Geçme kararını bloklayan bulgunun varlığı belirler; yüksek skor bloklayan bulguyu kapatmaz.

HARF NOTU

A	90 ve üzeri
B	80 – 89
C	70 – 79
D	60 – 69
F	60 altı

Skor yalnızca iyileşme trendini izlemek içindir.

GEÇME KARARI

- Bloklayan bulgu varsa proje geçmez — skor kaç olursa olsun.
- LLM kaynaklı bulgu skora eklenir, kapıyı tek başına kapatamaz.
- Yüksek güvenli LLM bulgusu bloklayan gibi ağırlıklandırılır.
- SAST katmanı çalışmadıysa sonuç geçerli değildir; kapsam eksiktir.

MATERYAL YETERLİLİĞİ

Kod tabanı 5 kaynak dosyadan veya 200 kod satırından küçükse skor üretilmez; sonuç “DEĞERLENDİRİLEMEDİ” olur ve hiçbir çerçeve kontrolü “Kanıt sağlandı” almaz.

Ölçülmüş örnek: tek satırlık bir “hello world” naif skorlamada 89/100 alırken gerçek bir kurumsal repo 45 almıştı. Kurala takılmamak, temiz olmak değildir.

SIRA KORUNUR — ÜÇ KATMAN VE YETKİLERİ

Deterministik araç katmanı — Ölçüm

Bulguyu üretir. Tekrarlanabilir, kanıtlanabilir, yorumsuz.

→

LLM katmanı — Yorum

Bulguyu yorumlar, eler ve araçların göremediğini arar.

→

Eşik katmanı — Karar

Kararı verir. Deterministik, müzakereye kapalı.

Sıranın bozulması — LLM’in kendi bulgusuyla kendi kararını vermesi — denetimi ölçümden yoruma indirger. Asimetrik yetki bu nedenle vardır: LLM kapıyı açamaz, yalnızca kapatılmasını isteyebilir.

RAPORUN KENDİSİNE UYGULANAN KURALLAR

Yanlış pozitif oranı rapora yazılır

Triage’ın kaç bulguyu elediği güvenilirlik göstergesidir; gizlenmez.

Kapsam dışı alan rapora yazılır

Yük testi, DAST, cross-file taint ve lisans provenance bu denetimin dışındadır.

Ayrıştırılamayan dosya taranmamış dosyadır

Bloklayıcı kalır ve dosya adıyla raporlanır; sessizce atlanmaz.

Dedektörü olmayan kategori uyarı üretir

Bulgu çıkmaması taramanın temiz olduğu anlamına gelmez — hiç taranmamıştır.

Tarama Soruları — Kullanım, Üretim ve Doğrulama

Mevcut durumu ve hangi kontrollerin eksik olduğunu belirleyen sorular. Olgunluk seviyesi ve yol haritası bu cevaplardan çıkar.

#	SORU	NEYİ BELİRLER	CEVABA GÖRE SONUÇ
1	**AI kodlama asistanı hangi ekiplerde, hangi işlerde kullanılıyor**	**Kapsamı**	Kullanım yaygınsa standart zorunlu olur; dağınıksa önce envanter çıkarılır
2	**Hangi asistan ve hangi dağıtım modeli — bulut servisi mi, kurum içi mi**	**Veri sınırını**	Bulut servisi: bağlam kurum dışına çıkar; veri sınıflandırma politikası ön koşul olur
3	**Asistana verilen bağlamın sınırı yazılı mı**	**Politika olgunluğunu**	Yazılı değilse önce bağlam politikası yazılır; teknik kontrol tek başına yetmez
4	**Kural dosyaları sürümleniyor ve review ediliyor mu**	**Davranış tutarlılığını**	Sürümlenmiyorsa aynı repoda farklı standartlar oluşmuştur; önce bu kapatılır
5	**Üretilen kodun testi kim ve nasıl yazıyor**	**Doğrulama bağımsızlığını**	Test de asistandan geliyorsa doğrulama katmanı yoktur; bağımsız test adımı kurulur
6	**İnsan review zorunlu mu, yoksa isteğe bağlı mı**	**Devredilemez katmanın varlığını**	İsteğe bağlıysa authorization ve iş mantığı kusurları hiçbir katmanda yakalanmıyor demektir
7	**Pre-commit kontrolü var mı — secret, gizli Unicode, büyük dosya**	**İlk kapının varlığını**	Yoksa en ucuz kapı eksiktir; ilk kurulacak kontrol budur
8	**Bağımlılıklar nasıl doğrulanıyor — paket varlığı, yaşı, lisansı**	**Tedarik zinciri riskini**	Doğrulama yoksa hallucinated package ve slopsquatting açıktır
9	**SBOM üretiliyor ve saklanıyor mu**	**Kanıt üretilebilirliğini**	Üretilmiyorsa zafiyet duyurusu geldiğinde etki analizi yapılamaz
10	**SAST hangi kategorileri kapsıyor — output encoding ve log sanitization dahil mi**	**Kapsam gerçekliğini**	Dahil değilse AI kodunun en zayıf kategorileri hiç taranmıyor demektir
11	**Commit disiplini nasıl — boyut ve açıklama beklentisi var mı**	**Atfedilebilirliği**	Büyük ve açıklamasız commit'ler varsa kök neden analizi sonradan kurulamaz

Cevapsız kalan her soru bir varsayımdır. Varsayımlar teklif metnine açıkça yazılır ve sözleşme öncesi netleştirilecek konular listesine taşınır.

Tarama Soruları — Kapı, Yönetişim ve Kapsam

Kontrolün bağlayıcı olup olmadığını ve kanıtın üretilebilirliğini belirleyen sorular.

#	SORU	NEYİ BELİRLER	CEVABA GÖRE SONUÇ
12	**CI kapısı var mı; advisory mi blocking mi çalışıyor**	**Kontrolün bağlayıcılığını**	Kapı yoksa bulgular üretilip tüketilmiyordur; önce advisory kurulur
13	**Bloklayan bulgu tanımı yazılı mı**	**Karar netliğini**	Yazılı değilse kapı kararı kişiye göre değişir; eşik merkezden tanımlanır
14	**Kural seti merkezden mi geliyor, yerel kopya düzenlenebiliyor mu**	**Ölçümün karşılaştırılabilirliğini**	Yerel kopya varsa projeler aynı ölçüyle ölçülmüyordur
15	**Eşik değiştirme yetkisi kimde**	**Yönetişim netliğini**	Proje ekibindeyse eşik zamanla aşınır; yetki tek bir sahipte toplanır
16	**Bulgu seti tarihli olarak saklanıyor mu**	**Kanıt sürekliliğini**	Saklanmıyorsa iyileşme gösterilemez; kurumsal müşteri zaman serisi ister
17	**Açık bloklayan bulguların ortalama kapanma süresi ölçülüyor mu**	**Süreç sağlığını**	Ölçülmüyorsa bulgular birikir; kapanma süresi tek başına bir olgunluk göstergesidir
18	**Triage yapılıyor mu; eleme gerekçeleri kayıtlı mı**	**Raporun güvenilirliğini**	Gerekçesiz eleme varsa rapor ölçüm değil görüştür
19	**Ekip büyüklüğü ve yazar sayısı ne**	**Hangi kontrollerin uygulanabilir olduğunu**	Tek yazarlı projede dört göz bulgusu “uygulanamaz” olarak sınıflanır, silinmez
20	**Kod hangi dağıtım hedefine gidiyor — iç araç, ürün, düzenlemeye tabi müşteri**	**Olgunluk seviyesini**	Düzenlemeye tabi müşteri: üretim kontrolleri zorunlu, kapı blocking olur
21	**Veri hassasiyeti ne — kişisel veri, finansal veri var mı**	**Kontrol setini**	Kişisel veri varsa seviye yukarı çekilir; pilot seviyesinde bırakılmaz
22	**Hangi uyum çerçevelerine kanıt üretilmesi bekleniyor**	**Rapor kapsamını**	Beklenti yoksa çerçeve eşlemesi gürültüdür; varsa kanıt durumu tablosu rapora eklenir

Bu sorular bir denetim değildir; denetimin hangi kapsamda anlamlı olacağını belirler. Cevaplar rapora yazılır, çünkü iki denetim arasında sonuç değiştiğinde bunun koddan mı bağlamdan mı geldiği ayırt edilebilmelidir.

Karar Kütüğü — Kullanım, Sorumluluk ve Kontrol Mimarisi

Alınan her kararın gerekçesi, reddedilen alternatifi ve hangi koşulda yeniden değerlendirileceği.

#	KONU	ALINAN KARAR	GEREKÇE VE ALTERNATİF	HANGİ KOŞULDA DEĞİŞİR
1	**Asistan kullanımı**	**Serbest — yasaklanmaz, kontrol altına alınır**	Yasak uygulanamaz; gölge kullanım üretir ve görünürlüğü tamamen kaybettirir. Reddedilen: belirli ekiplere izin, diğerlerine yasak.	Sözleşme veya düzenleme belirli bir projede dış servis kullanımını yasaklarsa o proje kapsam dışına alınır
2	**Sorumluluk**	**Kararın sahibi insandır; asistan çıktısı delil değildir**	Sorumluluğun araca devredilmesi, hiçbir kusurun sahibi olmaması demektir. Reddedilen: “asistan üretti” gerekçesinin hafifletici sayılması.	Değişmez — bu kararın bağlı olduğu bir koşul yoktur
3	**Test bağımsızlığı**	**Test kabul ölçütünden türetilir, ayrı adımda yazılır**	Aynı üretimden gelen test, kodun kendi iddiasını kendi doğrulaması anlamına gelir. Reddedilen: aynı oturumda kod ve test üretimi.	Mutasyon testi gibi bağımsız bir doğrulama katmanı kurulursa adım birleştirilebilir
4	**Kontrol sırası**	**Araç üretir, LLM yorumlar, eşik karar verir**	Yorumun ölçümün yerine geçmesi, denetimi tekrarlanabilir olmaktan çıkarır. Reddedilen: LLM’in doğrudan geçti/kaldı kararı vermesi.	Değişmez — sıra bozulursa sonuç denetim sayılmaz
5	**LLM yetkisi**	**Asimetrik — bulgu ekleyebilir, kapıyı kapatamaz**	Yanlış pozitif maliyeti ile kaçırılan bulgu maliyeti simetrik değildir. Reddedilen: LLM’e tam eleme yetkisi.	Yüksek güvenli LLM bulguları bloklayan gibi ağırlıklandırılır; bu ayar kalibre edilebilir
6	**Kural seti sahipliği**	**Merkezden tek kaynak; yerel kopya düzenlenmez**	Denetimin anlamı, herkesin aynı kural setiyle ölçülmesinden gelir. Reddedilen: proje bazında eşik istisnası.	Eşik değişikliği gerekçesiyle kural seti sahibine başvurulur; kabul edilirse sürümle herkese yayılır
7	**Materyal eşiği**	**5 dosya veya 200 satır altında skor üretilmez**	Küçük kod tabanı hiçbir kurala takılmaz ve gerçek bir projeden yüksek not alır. Reddedilen: her kod tabanına skor verilmesi.	Eşikler kalibre edilebilir; kaldırılamaz

Karar Kütüğü — Devreye Alma, Yönetişim ve Raporlama

Alınan her kararın gerekçesi, reddedilen alternatifi ve hangi koşulda yeniden değerlendirileceği.

#	KONU	ALINAN KARAR	GEREKÇE VE ALTERNATİF	HANGİ KOŞULDA DEĞİŞİR
8	**Devreye alma**	**İlk 4–6 hafta advisory, sonra blocking**	Erken sertleştirme ekibin denetimi bypass etmesine ve kontrolün kâğıt üstünde kalmasına yol açar. Reddedilen: ilk günden blocking.	Skor istikrarlı biçimde 85 üzerine çıkmadan blocking'e geçilmez
9	**Pilot kapsamı**	**Üç repo ile başlanır**	Dar pilot, kalibrasyon hatalarının düşük maliyetle görülmesini sağlar. Reddedilen: tüm repolarda aynı anda devreye alma.	Pilotta yanlış pozitif oranı kabul edilebilir seviyeye inince kapsam genişletilir
10	**Bağlam kullanımı**	**Bulgu susturulmaz, yeniden sınıflandırılır**	Bağlam bilgisi aksi halde denetimden kaçmanın yoluna dönüşür. Reddedilen: uygulanamaz bulguların rapordan çıkarılması.	Değişmez — kapsam kaybı her durumda görünür kalır
11	**Uyum dili**	**Üç durumlu: kanıt sağlandı / kısmi kanıt / kanıt üretilemedi**	Bir kod denetimi uyum kararı veremez; kararı veren akredite kuruluş, CPA veya QSA'dır. Reddedilen: "uyumlu değilsiniz" ifadesi.	Değişmez — bu bir yetki sınırıdır, tercih değil
12	**Çerçeve kapsamı**	**AI'a özgü maddeler çerçeve eşlemesi dışında tutulur**	Klasik çerçevelerde karşılığı olmayan maddeleri zorlamak raporun güvenilirliğini düşürür. Reddedilen: her maddeye bir kontrol numarası atanması.	İlgili çerçeveler AI kodu için kontrol tanımlarsa eşleme yeniden açılır
13	**Kanıt saklama**	**Bulgu seti tarih ve commit ile arşivlenir**	Kurumsal müşteri tek rapor değil zaman serisi ister; iyileşme ancak böyle gösterilir. Reddedilen: yalnızca son raporun saklanması.	Saklama süresi ve yeri kurumun veri saklama politikasına göre ayarlanır
14	**Kapsam beyanı**	**Kapsam dışı alanlar her raporda yazılır**	Yük testi, DAST, cross-file taint ve lisans provenance bu denetimin dışındadır. Reddedilen: "geçti" sonucunun genel güvence olarak sunulması.	Kapsam genişledikçe bu liste kısalır; boşaldığı iddia edilmez

Kavram Sözlüğü

Teklif ve sunumlarda geçen kavramların ortak tanımları. Terim tartışmasını kontrol tartışmasından ayırmak için kullanılır.

Vibe coding
Kodun büyük ölçüde AI asistanına ürettirildiği, geliştiricinin niyeti tanımlayıp çıktıyı yönlendirdiği çalışma biçimi.

AI kodlama asistanı
Kod, test ve dokümantasyon taslağı üreten model tabanlı araç. Karar vermez, sorumluluk taşımaz.

Kural dosyası (rules file)
Asistanın davranışını yönlendiren, repo içinde duran yapılandırma. Koda dahildir: sürümlenir ve review edilir.

Hallucinated package
Modelin var olmayan bir paket adı üretmesi. Saldırgan bu adı registry'ye kaydederek kodun içine girer.

Slopsquatting
Sık üretilen hatalı paket adlarının önceden registry'ye kaydedilmesiyle yapılan tedarik zinciri saldırısı.

Beyan borcu
Kodun uyguladığını iddia ettiği kontrolü gerçekte uygulamaması. Test aynı üretimden gelirse fark edilmez.

Bidi / gizli Unicode
Gözle görünmeyen veya yazım yönünü değiştiren karakterler. Kodun okunan hali ile çalışan halini ayırır.

SAST
Statik uygulama güvenlik testi. Kod çalıştırılmadan, kaynak üzerinde kusur kalıplarının aranması.

SCA
Yazılım bileşen analizi. Bağımlılıkların sürüm, lisans ve bilinen zafiyet açısından incelenmesi.

SBOM
Yazılım malzeme listesi. Hangi bileşenin hangi sürümünün kullanıldığının makine okunur envanteri.

Output encoding
Verinin gideceği bağlama göre kaçışının yapılması. XSS'in birincil savunmasıdır.

Log sanitization
Günlüğe yazılan girdinin temizlenmesi. Yapılmazsa saldırgan günlük kaydını manipüle edebilir.

SSRF
Sunucunun saldırgan tarafından belirlenen bir adrese istek yapmaya zorlanması.

CORS
Tarayıcının kaynaklar arası erişim kuralı. Gevşek yapılandırma veriyi başka alan adına açar.

Triage
Bulguların elenmesi, önceliklendirilmesi ve gerekçelendirilmesi süreci.

Yanlış pozitif
Aracın bulgu olarak işaretlediği ancak gerçekte kusur olmayan durum. Oranı rapora yazılır.

Bloklayan bulgu
Varlığı tek başına geçmeyi engelleyen bulgu. Skorla telafi edilemez.

Advisory / blocking mod
Kapının uyarı mı verdiği yoksa birleştirmeyi mi durdurduğu. Devreye alma advisory ile başlar.

Atfedilebilirlik
Bir değişikliğin kim tarafından, hangi gerekçeyle yapıldığının sonradan kurulabilmesi.

Kanıt paketi
Tarihli bulgu setlerinden oluşan zaman serisi. Trend, bulgu yaşam süresi ve kapanma süresini içerir.

Araç Eşleme Şablonu — Kontrol Bloklarının Araç Karşılıkları

Her kontrol bloğunun yaygın araç ailelerindeki karşılığı. Seçimi kurumun mevcut platformu, yetkinliği ve lisans durumu belirler.

Secret taraması

Açık kaynak araç
detect-secrets, gitleaks

Geliştirme platformu yerleşik
Push protection, secret scanning

Kurumsal denetim çerçevesi
Ağırlık 16 · bloklayan · pre-commit

Statik analiz (SAST)

Açık kaynak araç
semgrep, bandit

Geliştirme platformu yerleşik
Code scanning, yerleşik kural setleri

Kurumsal denetim çerçevesi
Ağırlık 14 · AI kör noktası kuralları ayrıca

Bağımlılık analizi (SCA)

Açık kaynak araç
pip-audit, OSV sorgusu

Geliştirme platformu yerleşik
Dependency alerts, otomatik yükseltme

Kurumsal denetim çerçevesi
Ağırlık 12 · paket yaşı ve varlık kontrolü

SBOM üretimi

Açık kaynak araç
CycloneDX, SPDX

Geliştirme platformu yerleşik
Yapılandırma ile derleme adımında

Kurumsal denetim çerçevesi
Commit ile birlikte saklanır

Konfigürasyon denetimi

Açık kaynak araç
config-lint, policy as code

Geliştirme platformu yerleşik
Ortam ve sır yönetimi ayarları

Kurumsal denetim çerçevesi
Ağırlık 9 · yorum/kod ayrımı yapılır

CI kapısı

Açık kaynak araç
Betik tabanlı eşik kontrolü

Geliştirme platformu yerleşik
Required checks, branch koruması

Kurumsal denetim çerçevesi
Advisory → blocking geçiş kuralı

LLM triage

Açık kaynak araç
Yok — model erişimi gerekir

Geliştirme platformu yerleşik
Yok

Kurumsal denetim çerçevesi
Ağırlık 12 · asimetrik yetki · gerekçe zorunlu

Kanıt arşivi

Açık kaynak araç
Dosya tabanlı tarihli arşiv

Geliştirme platformu yerleşik
Artefakt saklama

Kurumsal denetim çerçevesi
Zaman serisi · MTTR · açık bulgu izleme

Açık kaynak araç

Geliştirme platformu yerleşik

Kurumsal denetim çerçevesi

Bir hücrenin dolu olması yeterli olduğunu göstermez

Yetenek derinliği ve kapsam blok bazında değerlendirilir; dedektörü olmayan kategori rapora uyarı olarak yazılır.

LLM triage satırı boş kalıyor

Bu katmanın açık kaynak veya platform karşılığı yoktur; model erişimi ve gerekçe disiplini gerektirir.

Araç adları sık değişir

Bu alandaki ürün ve özellik adlandırmaları hızla değişmektedir; teklif öncesi güncel adlandırma teyit edilmelidir.

Yaygınlaştırma Yol Haritası

Kontrol tek adımda sertleştirilmez. Erken sertleştirme, ekibin denetimi bypass etmesine ve kontrolün kâğıt üstünde kalmasına yol açar.

FAZ 0 · Hazırlık

1 – 2 hafta

- Kural seti sahibi ve eşik değiştirme yetkisi yazılır
- Olgunluk seviyeleri ve veri hassasiyeti tanımları kabul edilir
- Pilot için üç repo seçilir
- Bağlam ve kural dosyası politikası yazılır

ÇIKIŞ KOŞULU — Sahiplik ve eşikler yazılı değilse pilot başlamaz

FAZ 1 · Advisory

4 – 6 hafta

- Kapı advisory modda kurulur; hiçbir birleştirme engellenmez
- Her koşuda bulgu seti tarihli olarak arşivlenir
- Yanlış pozitif oranı ölçülür ve kural seti kalibre edilir
- Ekibe bulgu okuma ve triage eğitimi verilir

ÇIKIŞ KOŞULU — Yanlış pozitif oranı kabul edilebilir seviyeye inmeden sonraki faza geçilmez

FAZ 2 · Skor izleme

4 – 8 hafta

- Skor trendi izlenir; bloklayan bulgu kapanma süresi ölçülür
- Triage süreci ve eleme gerekçesi disiplini yerleşir
- Kapsam pilot dışına kademeli genişletilir
- Çerçeve eşlemesi, beklentisi olan projelerde devreye alınır

ÇIKIŞ KOŞULU — Skor istikrarlı biçimde 85 üzerine çıkmadan blocking'e geçilmez

FAZ 3 · Blocking

sürekli

- Kapı blocking moda alınır; bloklayan bulgu birleştirmeyi durdurur
- Kanıt paketi düzenli olarak üretilir ve saklanır
- 14 günden uzun denetimsiz aralıklar raporlanır
- Yeni dedektörler bilgi → uyarı → blok sırasıyla devreye alınır

ÇIKIŞ KOŞULU — Geri dönüş yoktur; eşik düşürme talebi kural seti sahibine gider

Pilot üç repo ile sınırlı tutulur. Dar pilot, kalibrasyon hatalarının düşük maliyetle görülmesini sağlar: ölçülmüş bir koşuda monorepo yerel paketleri 52 yanlış bloklayan bulgu üretmişti.

Faz atlanmaz. Advisory aşaması olmadan doğrudan blocking'e geçilen kurulumlarda kontrol, bypass edilen bir formaliteye dönüşür ve ölçüm değeri kalmaz.

Denetimin Sınırları ve Uyum Çerçevesi Dili

Bir kod denetimi uyum kararı veremez. Neyin ölçülmediğinin yazılması, ölçülenin değerini korur.

KAPSAM DIŞI — HER RAPORDA YAZILIR

Yük ve dayanıklılık testi	Performans ve kapasite davranışı bu denetimde ölçülmez.
DAST / çalışan uygulama testi	Denetim kaynak kod üzerindedir; çalışan uygulamaya istek gönderilmez.
Cross-file taint analizi	Dosyalar arası veri akışı izlenmez; kusur kalıpları dosya düzeyinde aranır.
Lisans provenance	Lisans beyanı okunur; beyanın doğruluğu ayrıca doğrulanmaz.
İş süreci ve organizasyon	Görevler ayrılığı ve yetkilendirme süreçleri kod üzerinden ölçülemez.
Altyapı ve ağ güvenliği	Çalışma ortamı, ağ segmentasyonu ve erişim kontrolleri kapsam dışıdır.

“Geçti” sonucu bu alanlar için güvence değildir.

ÜÇ DURUMLU KANIT SKALASI

Kanıt sağlandı

İlgili kontrolün etkin işlediğine dair kod düzeyinde kanıt üretilmiştir.

Kısmi kanıt

Kanıtın bir kısmı üretilmiştir; kalan kısım bu denetimin kapsamı dışındadır.

Kanıt üretilemedi

Bu repoda ilgili kanıt üretilememiştir. Kontrolün işlemediği anlamına gelmez.

Kullanılmayan ifade: “uyumlu değilsiniz”. Bu bir yetki sınırıdır, tercih değil.

UYUM KARARINI KİM VERİR

ISO 27001
Akredite belgelendirme kuruluşu

SOC 2
Lisanslı CPA firması — görüş bildirir, geçti/kaldı yoktur

PCI DSS
QSA

CRA
Üretici veya onaylanmış kuruluş

Kullanılan dil

“Bu bulgu, ilgili kontrolün etkin işlediğine dair kanıtı zayıflatır.” / “Bu kapsamda denetçiye sunulacak kanıt bu repoda üretilememiştir.”

Neden böyle

Standartlar kodu değil yönetim sistemini belgeler; kontrollerin bir kısmının kod düzeyinde ölçülebilir karşılığı yoktur ve kapsam, uygulanabilirlik bildirimiyle belirlenir.

AI’a özgü maddeler

Klasik çerçevelerde karşılığı olmayan maddeler eşleme dışında tutulur. Zorlanmamaları raporun güvenilirliğini artırır.

BÖLÜM 3

FİRMA ÖNERİSİ

Buraya kadarki sayfalar kurum bağımsızdır ve hem iç standart hem de teklif eki olarak kullanılabilir. Bu bölümdeki sayfalar değerlendirme bulgularıyla doldurulur ve yalnızca ilgili kuruma aittir.

Mevcut durum özeti

Tarama sorularının cevapları, eksik kontroller ve bunların hangi riske karşılık geldiği.

Hedef kontrol seti

Olgunluk seviyesi, uygulanacak kapılar, eşikler ve kapsam dışı bırakılanlar.

Devreye alma planı

Faz takvimi, pilot kapsamı, sorumluluklar ve açık konular.

Firma Önerisi — Mevcut Durum Özeti

Tarama sorularının cevapları, eksik kontroller ve karşılık geldikleri risk. Değerlendirme çalışması sonrası doldurulur.

#	DEĞERLENDİRME ALANI	MEVCUT DURUM	RİSK KARŞILIĞI	KRİTİKLİK
1	Kullanım yaygınlığı ve asistan seçimi			
2	Bağlam ve kural dosyası politikası			
3	Test bağımsızlığı			
4	İnsan review zorunluluğu			
5	Pre-commit kontrolleri			
6	Bağımlılık doğrulaması ve SBOM			
7	Statik analiz kapsamı			
8	CI kapısı ve eşikler			
9	Kural seti sahipliği			
10	Kanıt arşivi ve izlenebilirlik			

Her eksik kontrol bir risk karşılığına bağlanır; karşılığı yazılamayan madde rapora girmez. Ekip yapısı gereği uygulanamayan maddeler silinmez, “uygulanamaz — gerekçe” olarak işaretlenir.

Firma Önerisi — Hedef Kontrol Seti

Olgunluk seviyesi, uygulanacak kapılar, eşikler ve kapsam dışı bırakılanlar. Kontrol kapıları sayfasıyla birlikte okunur.

SEVİYE 1

Prototip

seçildi / seçilmedi — işaretlenecek

SEVİYE 2

Pilot

seçildi / seçilmedi — işaretlenecek

SEVİYE 3

Üretim

seçildi / seçilmedi — işaretlenecek

UYGULANACAK KAPILAR

K1–K8 arasından hangileri, hangi modda — advisory veya blocking

EŞİKLER VE AĞIRLIKLAR

Kullanılan kural seti sürümü ve varsa gerekçelendirilmiş sapmalar

KAPSAM DIŞI BIRAKILANLAR

Hangi repolar, hangi kategoriler, hangi gerekçeyle

AÇIK KONULAR VE VARSAYIMLAR

Cevapsız tarama soruları ve teklife yazılacak varsayımlar

Eşik sapması proje bazında tanımlanmaz. Bu sayfada yazılan her sapma, kural seti sahibine başvurulmuş ve kabul edilmiş olmalıdır.

Firma Önerisi — Devreye Alma Planı

Faz takvimi, pilot kapsamı, sorumluluklar ve açık konular.

FAZ	KAPSAM	BAŞLANGIÇ	BİTİŞ	SORUMLU VE ÇIKIŞ KOŞULU

PİLOT KAPSAMI

Seçilen üç repo, gerekçesi ve beklenen bulgu profili

ARAÇ SEÇİMİ VE GEREKÇESİ

Blok bazında seçilen araçlar ve mevcut platformla uyumu

AÇIK KONULAR

Netleştirilecek maddeler ve sorumlu taraf

Her fazın bir çıkış koşulu vardır. Çıkış koşulu yazılmayan faz süresiz uzar ve advisory modda kalan bir kontrol, zamanla okunmayan bir rapora dönüşür.